

SOC2 Quarterly Access Review Procedure

Scope and cadence

Every quarter, within the first 10 business days, Meridian reviews all human and service access to production systems: SSH to hosts, Postgres roles, Kubernetes RBAC, Vault policies, and the CI/CD deploy credentials. The review is owned by the platform lead; the security officer countersigns.

Sources of record: the service inventory sheet (service-inventory.csv) for ownership, Vault audit logs for secret access, and the IdP group export for human accounts. Access not traceable to a row in the inventory is revoked by default.

SOC2 Quarterly Access Review Procedure

Procedure

1. Export current grants: Postgres roles via `pg_roles`, Kubernetes bindings via `kubectl get rolebindings -A`, Vault policies via `vault policy list`. 2. Diff against last quarter's approved baseline. 3. For each addition, find the approving change ticket; additions without one are revoked within 5 business days. 4. Dormant human accounts (no login in 90 days) are disabled. 5. Service API keys older than 180 days trigger the rotation runbook (see: Rotating Service API Keys via Vault).

Evidence bundle: the signed diff, the revocation list, and ticket links are stored in the compliance vault under `access-reviews/<year>-Q<n>` and retained for 3 years.